

# Reference Manual — Trusted Agentic Commerce for Magento 2

Version 1.3.4 · Technical Reference for Developers and System Integrators

---

## Table of contents

1. [Module architecture](#)
  2. [Configuration reference](#)
  3. [Database schema](#)
  4. [Events and observers](#)
  5. [Cron jobs](#)
  6. [ACL resources](#)
  7. [Admin routes](#)
  8. [Frontend routes](#)
  9. [Services](#)
  10. [Enforcement engine](#)
  11. [Webhook outbox](#)
  12. [Agent token verification](#)
  13. [MCP manifest](#)
  14. [Extension attributes](#)
  15. [API endpoints called](#)
  16. [Security model](#)
  17. [Console commands](#)
  18. [Data patches](#)
  19. [Di.xml wiring](#)
  20. [Logging](#)
-

## 1. Module architecture

|                         |                                                          |
|-------------------------|----------------------------------------------------------|
| Trusted_AgenticCommerce |                                                          |
| ├─ Block/Adminhtml/     | SPA placeholder blocks for admin pages                   |
| ├─ Console/Command/     | CLI commands (check-webserver, webhook:status)           |
| ├─ Controller/          |                                                          |
| │   ├─ Adminhtml/       | Admin controllers (Dashboard, Setup, Health, etc.)       |
| │   └─ Wellknown/       | Frontend /.well-known/mcp.json endpoint                  |
| ├─ Cron/                | Webhook drainer + lag heartbeat                          |
| ├─ Enforcement/         | R043 HITL gate logic                                     |
| ├─ Model/               |                                                          |
| │   ├─ Config/          | ScopeConfig readers + SSRF validator                     |
| │   ├─ Manifest/        | MCP manifest builder                                     |
| │   ├─ Security/        | HMAC signer + API URL validator                          |
| │   ├─ Setup/           | Setup wizard data provider                               |
| │   ├─ Storefront/      | Hyvä/PWA theme detector                                  |
| │   └─ Webhook/         | Outbox repository + signature publisher                  |
| ├─ Observer/            | Magento event hooks (order, shipment, payment)           |
| ├─ Plugin/              | Order extension attribute plugin                         |
| ├─ Router/              | /.well-known URL router                                  |
| ├─ Service/             | EnforcementClient, AgentTokenVerifier, CartSignals       |
| ├─ Setup/Patch/Data/    | Data patches (EAV attribute, Hyvä bridge, install event) |
| ├─ Test/                |                                                          |
| │   ├─ Integration/     | Integration test suite                                   |
| │   ├─ Static/          | Route consistency checker                                |
| │   └─ Unit/            | Unit test suite                                          |
| ├─ etc/                 | Module XML, DI, ACL, events, cron, system config         |
| ├─ i18n/                | Translation files                                        |
| └─ view/                | Admin layout + templates                                 |

**Module name:** `Trusted_AgenticCommerce` **Composer package:** `trusted/agentic-commerce-magento` **PHP namespace:** `Trusted\AgenticCommerce` **Setup version:** none (uses Data Patches exclusively)

## 2. Configuration reference

All paths are under `Stores → Configuration → Trusted → Agentic Commerce` (`trusted_general` section in `system.xml`).

## Group: API Connection ( `trusted_general/general` )

| Field                  | Config Path                                                 | Type    | Scope   | Description                                                                                                                                                                                                                                |
|------------------------|-------------------------------------------------------------|---------|---------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| API Base URL           | <code>trusted_general/general/api_base_url</code>           | text    | Global  | Trusted API root (must be HTTPS). Default: <code>https://api.trusted.xyz</code>                                                                                                                                                            |
| Merchant ID            | <code>trusted_general/general/merchant_id</code>            | text    | Global  | Assigned by Trusted at account creation                                                                                                                                                                                                    |
| Integration Token      | <code>trusted_general/general/integration_token</code>      | obscure | Global  | Bearer token for outbound API calls. Stored encrypted via <code>Magento\Config\Model\Config\Backend\Encrypted</code>                                                                                                                       |
| Webhook Secret         | <code>trusted_general/general/webhook_secret</code>         | obscure | Global  | HMAC-SHA256 secret for signing webhook deliveries. Stored encrypted                                                                                                                                                                        |
| Internal HMAC Secret   | <code>trusted_general/general/internal_hmac_secret</code>   | obscure | Global  | Signs internal heartbeat calls with the <code>X-Trusted-Connection-Id</code> , <code>X-Trusted-Timestamp</code> and <code>X-Trusted-Signature</code> headers. The older <code>X-Internal-Auth</code> scheme is rejected by the Trusted API |
| Webhook Secret Version | <code>trusted_general/general/webhook_secret_version</code> | text    | Global  | Increment when rotating the webhook secret. Used in the <code>X-Trusted-Webhook-Secret-Version</code> header                                                                                                                               |
| Connection ID          | <code>trusted_general/general/connection_id</code>          | text    | Website | Assigned by Trusted after connecting. Identifies this store in webhook delivery                                                                                                                                                            |

## Group: Features ( `trusted_general/features` )

| Field                | Config Path                                           | Type   | Scope   | Description                                                                                               |
|----------------------|-------------------------------------------------------|--------|---------|-----------------------------------------------------------------------------------------------------------|
| Enable WebMCP Bridge | <code>trusted_general/features/webmcp_enabled</code>  | select | Website | Injects storefront JS bridge. Auto-disabled on Hyvä/PWA Studio via <code>DisableBridgeOnHyva</code> patch |
| Enable Phase B       | <code>trusted_general/features/phase_b_enabled</code> | select | Global  | Reserved for future embedded SPA. Do not enable                                                           |

## Enforcement paths

| Config Path                                      | Description                                                                                                                         |
|--------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------|
| <code>trusted/enforcement/failure_mode</code>    | <code>observe</code> or <code>enforce</code> . Default: <code>enforce</code> . You can change it in <b>Trusted → Adjustes</b>       |
| <code>trusted/enforcement/installation_id</code> | Enforcement Installation ID that Trusted provides. You enter it in the Setup Wizard                                                 |
| <code>trusted/enforcement/hmac_secret</code>     | Enforcement HMAC Secret that Trusted provides, used to sign <code>POST /v1/rules/evaluate</code> . You enter it in the Setup Wizard |

## 3. Database schema

Table: `trusted_webhook_outbox`

Reliable delivery outbox for order events. Entries are created by observers and drained every minute by the `trusted_webhook_drain` cron job.

| Column                       | Type                           | Nullable | Description                                                                                                                                                       |
|------------------------------|--------------------------------|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <code>id</code>              | int unsigned<br>AUTO_INCREMENT | No       | Primary key                                                                                                                                                       |
| <code>event_id</code>        | varchar(36)<br>UNIQUE          | No       | UUID v4 event identifier<br>(idempotency key)                                                                                                                     |
| <code>event_type</code>      | varchar(32)                    | No       | <code>order_created</code> ,<br><code>order_completed</code> ,<br><code>order_refunded</code> ,<br><code>order_cancelled</code> ,<br><code>order_fulfilled</code> |
| <code>entity_id</code>       | int unsigned                   | No       | Magento order <code>entity_id</code>                                                                                                                              |
| <code>increment_id</code>    | varchar(32)                    | No       | Magento order increment ID<br>(e.g. <code>000000001</code> )                                                                                                      |
| <code>composite_id</code>    | varchar(64)                    | No       | Composite ID in format<br><code>MAG:&lt;entity_id&gt;</code>                                                                                                      |
| <code>store_view_code</code> | varchar(32)                    | No       | Store view code at time of<br>event                                                                                                                               |
| <code>payload</code>         | text                           | No       | Serialized order payload (JSON)                                                                                                                                   |
| <code>status</code>          | varchar(16)                    | No       | <code>pending</code> , <code>delivered</code> , <code>dead</code>                                                                                                 |
| <code>retry_count</code>     | int unsigned                   | No       | Delivery attempt count. Default:<br>0                                                                                                                             |
| <code>secret_version</code>  | int unsigned                   | No       | Webhook secret version at time<br>of enqueue                                                                                                                      |
| <code>next_attempt_at</code> | timestamp                      | Yes      | Earliest eligible delivery time<br>(exponential backoff). NULL =<br>eligible immediately                                                                          |
| <code>locked_until</code>    | timestamp                      | Yes      | Lease lock expiry (worker lease<br>mechanism)                                                                                                                     |
| <code>locked_by</code>       | varchar(64)                    | Yes      | Process identifier holding the<br>lease                                                                                                                           |
| <code>created_at</code>      | timestamp                      | No       | Entry creation time                                                                                                                                               |
| <code>updated_at</code>      | timestamp                      | No       | Last modification time (auto-<br>updated)                                                                                                                         |

Indexes:

- `TRUSTEED_WEBHOOK_OUTBOX_EVENT_ID` (UNIQUE) on `event_id`
- `TRUSTEED_WEBHOOK_OUTBOX_STATUS_CREATED_AT` on `(status, created_at)`
- `TRUSTEED_WEBHOOK_OUTBOX_LOCKED_UNTIL` on `locked_until`
- `TRUSTEED_WEBHOOK_OUTBOX_STATUS_NEXT_ATTEMPT` on `(status, next_attempt_at, created_at)`

Columns added to `sales_order`

| Column                              | Type                      | Description                                                    |
|-------------------------------------|---------------------------|----------------------------------------------------------------|
| <code>trusted_receipt_uri</code>    | varchar(1024)<br>nullable | TrustReceipt URI. Immutable once set                           |
| <code>trusted_receipt_status</code> | varchar(16) nullable      | <code>signed</code> . Set when the receipt URI is first stored |

## 4. Events and observers

| Magento Event                                        | Observer Class                               | Purpose                                                                                                                                                                                                                         |
|------------------------------------------------------|----------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <code>sales_order_save_after</code>                  | <code>SalesOrderSaveAfter</code>             | Enqueues <code>order_created</code> (new, processing and on-hold orders), <code>order_completed</code> , <code>order_refunded</code> (closed orders) and <code>order_cancelled</code> events to the outbox based on order state |
| <code>sales_order_creditmemo_save_after</code>       | <code>SalesCreditmemoSaveAfter</code>        | Enqueues <code>order_refunded</code> for partial refunds (full refunds handled via <code>STATE_CLOSED</code> in <code>sales_order_save_after</code> )                                                                           |
| <code>sales_model_service_quote_submit_before</code> | <code>CheckoutSubmitBefore</code>            | Pre-order enforcement: verifies agent token, calls <code>/v1/rules/evaluate</code> , applies HITL freeze (R043) or throws <code>LocalizedException</code> on BLOCK                                                              |
| <code>sales_order_payment_failed</code>              | <code>SalesOrderPaymentFailedObserver</code> | Sends an HMAC-signed checkout-failure signal to <code>/api/v1/checkout-failures</code> for R011 tracking. It does not use the outbox                                                                                            |
| <code>sales_order_shipment_save_after</code>         | <code>ShipmentSaveAfter</code>               | Enqueues <code>order_fulfilled</code> when a shipment is created                                                                                                                                                                |

## Plugin

| Plugin Class                         | Target                                                  | Method            | Type   | Purpose                                                                                    |
|--------------------------------------|---------------------------------------------------------|-------------------|--------|--------------------------------------------------------------------------------------------|
| <code>OrderRepositoryPlugin</code>   | <code>Magento\Sales\Api\OrderRepositoryInterface</code> | <code>get</code>  | after  | Loads <code>trusted_r</code> and <code>trusted_r</code> extension attributes on order load |
| <code>OrderExtensionAttribute</code> | <code>Magento\Sales\Api\OrderRepositoryInterface</code> | <code>save</code> | around | Persists extension attributes on                                                           |

## 5. Cron jobs

Both jobs are in the `default` cron group and run every minute.

### `trusted_webhook_drain`

**Class:** `Trusteed\AgenticCommerce\Cron\DrainOutbox`

Processes the `trusted_webhook_outbox` table:

1. Selects entries where `status = 'pending'` AND ( `next_attempt_at IS NULL` OR `next_attempt_at ≤ NOW()` ) AND ( `locked_until IS NULL` OR `locked_until < NOW()` )
2. Acquires a lease ( `locked_by = <worker-id>` , `locked_until = NOW() + 60s` )
3. POSTs the payload to `POST /api/v1/webhook/magento/<connection_id>` with the signature headers described in [Webhook outbox](#)
4. On success (2xx): sets `status = 'delivered'`
5. On failure: increments `retry_count` , sets an exponential `next_attempt_at` (  $2 \times \text{retry\_count}$  , capped at 1 hour, with  $\pm 20\%$  jitter)
6. After 8 retries: sets `status = 'dead'`

### `trusted_lag_heartbeat`

**Class:** `Trusteed\AgenticCommerce\Cron\EmitLagHeartbeat`

Every minute, calculates the age of the oldest `pending` outbox entry and reports it to `POST /api/v1/internal/magento/lag-heartbeat` so the Trusteed dashboard can alert on delivery lag.

## 6. ACL resources

| Resource ID                                  | Title                           | Notes                                                                   |
|----------------------------------------------|---------------------------------|-------------------------------------------------------------------------|
| <code>Trusted_AgenticCommerce::config</code> | Trusted<br>Agentic<br>Commerce  | Grants access to all Trusted admin pages                                |
| <code>Trusted_AgenticCommerce::token</code>  | Trusted<br>Embed Token<br>Relay | Grants access to the token issue<br>controller used by the Setup Wizard |

To grant a custom role access to Trusted pages, add `Trusted_AgenticCommerce::config` in **System → Permissions → User Roles → [Role] → Role Resources**.

## 7. Admin routes

Front name: `trusted` (defined in `etc/adminhtml/routes.xml`)

| URL Pattern                                  | Controller                                              | Description               |
|----------------------------------------------|---------------------------------------------------------|---------------------------|
| <code>/trusteed/dashboard/index</code>       | <code>Controller/Adminhtml/Dashboard/Index</code>       | Dashboard SPA host        |
| <code>/trusteed/health/index</code>          | <code>Controller/Adminhtml/Health/Index</code>          | Store health SPA          |
| <code>/trusteed/ventas/index</code>          | <code>Controller/Adminhtml/Ventas/Index</code>          | Agent sales SPA           |
| <code>/trusteed/agentes/index</code>         | <code>Controller/Adminhtml/Agentes/Index</code>         | Agent directory SPA       |
| <code>/trusteed/reglas/index</code>          | <code>Controller/Adminhtml/Reglas/Index</code>          | Rules SPA                 |
| <code>/trusteed/pagos/index</code>           | <code>Controller/Adminhtml/Pagos/Index</code>           | Payment methods SPA       |
| <code>/trusteed/seguridad/index</code>       | <code>Controller/Adminhtml/Seguridad/Index</code>       | Security SPA              |
| <code>/trusteed/ajustes/index</code>         | <code>Controller/Adminhtml/Ajustes/Index</code>         | Settings SPA              |
| <code>/trusteed/setup/wizard</code>          | <code>Controller/Adminhtml/Setup/Wizard</code>          | Setup Wizard              |
| <code>/trusteed/setup/save</code>            | <code>Controller/Adminhtml/Setup/Save</code>            | Setup Wizard save action  |
| <code>/trusteed/setup/introspecttoken</code> | <code>Controller/Adminhtml/Setup/IntrospectToken</code> | Token introspection AJAX  |
| <code>/trusteed/token/issue</code>           | <code>Controller/Adminhtml/Token/Issue</code>           | Issues embed token (POST) |
| <code>/trusteed/support/submit</code>        | <code>Controller/Adminhtml/Support/Submit</code>        | Support form submit       |

## 8. Frontend routes

Front name: `nlweb` (defined in `etc/frontend/routes.xml` — the route `id` and `frontName` are both `nlweb`; there is no `trusteed` frontend route)

| URL Pattern                               | Controller                                    | Description                             |
|-------------------------------------------|-----------------------------------------------|-----------------------------------------|
| <code>/nlweb/products/index</code>        | <code>Controller/Products/Index</code>        | NLWeb product search endpoint (proxied) |
| <code>/nlweb/wellknown/mcpmanifest</code> | <code>Controller/Wellknown/McpManifest</code> | Returns the MCP manifest JSON           |

`/.well-known/mcp.json` is the canonical manifest URL and the one agents use. It is **not** reached through the `nlweb` frontName: it is matched by `Router/WellKnownRouter.php`, a custom router registered with `sortOrder=10` in `etc/frontend/di.xml`, which dispatches the `Controller/`

`Wellknown/McpManifest` action directly. The `/nlweb/wellknown/mcpmanifest` path above is the same controller reached through the ordinary `frontName`, and exists only as a fallback for web servers that cannot be made to rewrite the dotted `/.well-known/` path.

## 9. Services

### `EnforcementClient`

**Class:** `Trusted\AgenticCommerce\Service\EnforcementClient`

HTTP client for the Trusted rule evaluation API.

| Method                                                                       | Returns                                                         | Description                                                                                                                                                                                |
|------------------------------------------------------------------------------|-----------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <code>evaluate(array \$payload): string</code>                               | <code>ALLOW</code>   <code>BLOCK</code>   <code>ESCALATE</code> | Calls <code>POST /v1/rules/evaluate</code> . On transport error, tries the offline safety valve first, then returns <code>BLOCK</code> (enforce mode) or <code>ALLOW</code> (observe mode) |
| <code>getDidResolver(string \$merchantId): array</code>                      | <code>array&lt;{did, publicKeyJwk}&gt;</code>                   | Fetches agent DID → public key map from the snapshot. Empty array on failure                                                                                                               |
| <code>getRules(string \$merchantId): array</code>                            | <code>array&lt;{ruleCode, params, mode, enabled}&gt;</code>     | Fetches rule configuration from the snapshot                                                                                                                                               |
| <code>consumeNonce(string \$agentDid, string \$jti, int \$exp): array</code> | <code>{outcome, reason, httpStatus}</code>                      | Registers a single-use nonce for replay protection                                                                                                                                         |

**Signature format (Stripe-style):**

```
X-Trusted-Signature: t=<unix-timestamp>,s=<hmac-sha256-hex>
```

where the HMAC is computed over `"<timestamp>.<rawBody>"`.

### `AgentTokenVerifier`

**Class:** `Trusted\AgenticCommerce\Service\AgentTokenVerifier`

Verifies Ed25519-signed agent JWT tokens:

1. Parses JWT header/payload (no library dependency, raw base64url decode)
2. Looks up the agent's public key from the snapshot (`getDidResolver`)
3. Verifies the Ed25519 signature using `sodium_crypto_sign_verify_detached` (or `paragonie/sodium_compat` fallback)

- Validates `exp`, `iat`, `iss`, `aud` claims
- Calls `consumeNonce` for replay protection

#### `CartSignals`

**Class:** `Trusted\AgenticCommerce\Service\CartSignals`

Extracts cart-level signals from a Magento quote for inclusion in the `/v1/rules/evaluate` payload:

- Cart total
- Item count
- Product category IDs
- Agent metadata from quote custom attributes

#### `AgentHistoryFetcher`

**Class:** `Trusted\AgenticCommerce\Service\AgentHistoryFetcher`

Fetches the agent's order history from the Trusted API to populate the `/v1/rules/evaluate` `agentHistory` context field.

## 10. Enforcement engine

### Flow

```
sales_model_service_quote_submit_before
↓
CheckoutSubmitBefore::execute()
↓
Is this an agent order? (checkout session has trusted_agent_token)
↓ YES
AgentTokenVerifier::verify()
↓ VALID / INVALID / UNVERIFIED
EnforcementClient::evaluate({
    merchantId, agentId, orderContext,
    platform: "MAGENTO",
    installationId, timestamp
})
↓
ALLOW → continue (order is created normally)
BLOCK → throw LocalizedException (order is NOT created)
ESCALATE → freeze quote (is_active=0), stamp HITL flags, throw LocalizedException
```

Human checkouts also go through `evaluate()`, with `agentId` set to `null`, so your merchant rules apply to them too.

## ESCALATE (R043 HITL)

When `evaluate()` returns `ESCALATE`:

1. `R043HitlGate::buildFreezePayload()` extracts rule code, reason, and evaluation ID
2. The quote is stamped with custom metadata:
  - `trusted_hitl_pending = 1`
  - `trusted_hitl_rule_code = <ruleCode>`
  - `trusted_hitl_reason = <reason>`
  - `trusted_hitl_evaluation_id = <evaluationId>`
3. Quote `is_active` is set to `0` (prevents customer-facing recapture)
4. A `LocalizedException` is thrown, so Magento does not create the order
5. The intent appears in the Trusted dashboard for merchant review

### Failure mode

When the `evaluate()` call fails (transport error, non-2xx response or a rejected API base URL), the module first tries the offline safety valve. It checks the last rules snapshot against R014 (country check only), R018, R019, R020, R025, R027, R028, R029 and R030, and returns `BLOCK` on a match. If nothing matches, the failure mode decides:

| Config value                   | Behavior                                           |
|--------------------------------|----------------------------------------------------|
| <code>enforce</code> (default) | Returns <code>BLOCK</code> . The order is rejected |
| <code>observe</code>           | Returns <code>ALLOW</code> . The order proceeds    |

## 11. Webhook outbox

### Delivery payload format

Each entry is delivered with `POST <api_base_url>/api/v1/webhook/magento/<connection_id>`. This is the body of an order-state event ( `sales_order_save_after` ):

```

{
  "event_id": "<uuid-v4>",
  "event_type": "order_created",
  "entity_id": 1,
  "increment_id": "000000001",
  "composite_id": "MAG:1",
  "store_view_code": "default",
  "updated_at": "2026-06-18T10:00:00+00:00",
  "payload": {
    "grand_total": 99.99,
    "status": "pending",
    "state": "new",
    "customer_email": null,
    "agent_did": null
  }
}

```

`customer_email` is always `null`, because the payload leaves out personal data. `agent_did` holds the verified agent identity for agent orders and is `null` for human checkouts.

## Signature headers

```

Authorization: Bearer <integration token>
X-Trusted-Signature: <hex hmac-sha256>
X-Trusted-Timestamp: <unix seconds>
X-Trusted-Nonce: <32 hex characters>
X-Trusted-Webhook-Secret-Version: 1

```

HMAC input, keyed with the webhook secret: `"<timestamp>.<nonce>.<secretVersion>.<rawBody>"`

## Retry schedule

Exponential backoff, computed by `Cron/DrainOutbox.php::backoffDelaySeconds()`:

```

delay = min(2 × 2^retry_count, 3600) ± 20% jitter

```

The base is **2 seconds** (`BACKOFF_BASE_SECONDS`), the cap **3600 seconds** (`BACKOFF_MAX_SECONDS`), and symmetric  $\pm 20\%$  jitter (`BACKOFF_JITTER_RATIO = 0.20`) is applied to avoid thundering-herd retries across pods. The delay never falls below the 2-second base. The cron does not sleep; it stamps `next_attempt_at` and returns.

| Attempt ( <code>retry_count</code> ) | Nominal delay before next attempt |
|--------------------------------------|-----------------------------------|
| 0                                    | 2 s                               |
| 1                                    | 4 s                               |
| 2                                    | 8 s                               |
| 3                                    | 16 s                              |
| ...                                  | doubles each time                 |
| 11 and beyond                        | 3600 s (capped)                   |

After **8 attempts** ( `OutboxRepository::MAX_RETRIES = 8` ) the row is marked `dead`. Dead entries are not retried. Each drain run processes at most 50 rows ( `BATCH_SIZE` ) and stops after 55 seconds ( `MAX_RUNTIME_SECONDS` ).

## 12. Agent token verification

Agent tokens are JWTs signed with Ed25519 (algorithm `EdDSA`, curve `Ed25519` ).

### Token claims

All of `iss`, `aud`, `exp`, `iat`, `nonce` and `jti` are **mandatory**. A token that omits any of them is rejected as `invalid` (see `Service/AgentTokenVerifier.php` ).

| Claim                   | Type           | Validated as                                                                                                   |
|-------------------------|----------------|----------------------------------------------------------------------------------------------------------------|
| <code>iss</code>        | string         | Agent DID. Must equal the DID derived from the header <code>kid</code> — key-confusion guard                   |
| <code>aud</code>        | string         | Must be the literal <code>trusted</code> . (This is <b>not</b> the merchant ID)                                |
| <code>merchantId</code> | string         | Optional. When present, must match the store's configured Merchant ID                                          |
| <code>exp</code>        | unix timestamp | Expiry. Rejected once <code>now &gt; exp + 30</code> (30-second clock-skew tolerance)                          |
| <code>iat</code>        | unix timestamp | Issued at. Rejected once <code>now - iat &gt; 330</code> ( <code>MAX_AGE_SECONDS</code> )                      |
| <code>nonce</code>      | string         | Mandatory, 16–64 characters                                                                                    |
| <code>jti</code>        | string         | Single-use identifier, must match <code>/^[A-Za-z0-9_-]{16,128}\$/</code> ; missing → <code>missing_jti</code> |

`sub` and `platform` are not read by the verifier. The maximum token age is therefore **330 seconds** from `iat`, not 300.

### Verification outcomes

| Outcome                 | Meaning                                                 |
|-------------------------|---------------------------------------------------------|
| <code>VERIFIED</code>   | Signature valid, claims valid, nonce not replayed       |
| <code>INVALID</code>    | Signature invalid, token expired, or nonce already used |
| <code>UNVERIFIED</code> | No token present or token could not be parsed           |

### Public key resolution

Agent public keys are fetched from the enforcement snapshot ( `GET /v1/rules/snapshot/<merchantId>` ) as a JWK set. The snapshot is cached in-memory for the duration of the request to avoid repeated API calls.

## 13. MCP manifest

**Endpoint:** `GET /.well-known/mcp.json` **Controller:**

`Trusted\AgenticCommerce\Controller\Wellknown\McpManifest` **Builder:**

`Trusted\AgenticCommerce\Model\Manifest\Builder`

The manifest tells AI agents what capabilities your store exposes. It is signed with an Ed25519 key provisioned by Trusted.

## Manifest fields

```
{
  "schema_version": "1.0",
  "issuer": "https://api.trusted.xyz",
  "merchant_id": "<merchant-id>",
  "store_views": [
    { "code": "default", "base_url": "https://your-store.com" },
    { "code": "fr", "base_url": "https://your-store.fr" }
  ],
  "capabilities": ["checkout", "catalog_search", "order_status"],
  "updated_at": "<iso8601>",
  "signature": {
    "jws": "<detached-jws-compact>",
    "kid": "<key-id>",
    "alg": "EdDSA",
    "signed_at": "<iso8601>"
  }
}
```

Notes on the actual shape:

- `capabilities` is a flat **array of three strings** — `checkout`, `catalog_search`, `order_status` — not an object of feature flags, and it carries no payment-method list.
- `signature` is an **object** ( `jws` / `kid` / `alg` / `signed_at` ), not a bare JWS string.
- `issuer` is the configured Trusted API base URL. There are no `store_url`, `connection_id`, `platform`, `mcp_endpoint` or `issued_at` fields.
- `store_views[]` lists every published store view with its base URL, so agents can do longest-prefix matching across multiple domains.
- The `signed_payload` returned by the backend is served **verbatim**: the backend is authoritative for `issuer`, `merchant_id` and `capabilities` (ADR-014), and serving its exact bytes is what makes the detached JWS verify against what the agent received.
- `schema_version` is the key `bin/magento trusted:check-webserver` looks for when deciding whether the endpoint is serving a real manifest.

## 14. Extension attributes

The module adds extension attributes to `Magento\Sales\Api\Data\OrderInterface`:

| Attribute                           | Type   | Description                                                                              |
|-------------------------------------|--------|------------------------------------------------------------------------------------------|
| <code>trusted_receipt_uri</code>    | string | TrustReceipt URI                                                                         |
| <code>trusted_receipt_status</code> | string | Receipt status. The module sets <code>signed</code> when it first stores the receipt URI |

Defined in `etc/extension_attributes.xml`. Loaded/saved via `Plugin/Sales/OrderExtensionAttribute.php` and `Plugin/Repository/OrderRepositoryPlugin.php`.

---

## 15. API endpoints called

The module makes outbound HTTPS calls to the Trusted API. All calls require HTTPS and are validated by `ApiBaseUrlValidator` (SSRF guard).

| Method | Path                                   | When                                    | Auth                                                                                                     | Timeout |
|--------|----------------------------------------|-----------------------------------------|----------------------------------------------------------------------------------------------------------|---------|
| POST   | /v1/rules/evaluate                     | On every checkout attempt               | X-Trusteed-Installation-Id + X-Trusteed-Signature (HMAC)                                                 | 5 s     |
| GET    | /v1/rules/snapshot/<merchantId>        | Per-request cache miss                  | X-Trusteed-Installation-Id + X-Trusteed-Signature (HMAC)                                                 | 5 s     |
| POST   | /v1/agent-events/nonce-consume         | After token verification                | X-Trusteed-Installation-Id + X-Trusteed-Signature (HMAC)                                                 | 5 s     |
| GET    | /.well-known/jwks.json                 | Snapshot signature verification         | none (public keys)                                                                                       | 5 s     |
| POST   | /api/v1/webhook/magento/<connectionId> | Outbox delivery (order/shipment/refund) | Bearer + X-Trusteed-Signature, X-Trusteed-Timestamp, X-Trusteed-Nonce, X-Trusteed-Webhook-Secret-Version | 10 s    |
| POST   | /api/v1/internal/magento/lag-heartbeat | Every minute (lag monitor cron)         | X-Trusteed-Connection-Id + X-Trusteed-Timestamp + X-Trusteed-Signature (internal HMAC)                   | 10 s    |
| POST   | /api/v1/internal/magento/event         | Install-event data patch                | X-Trusteed-Connection-Id + X-Trusteed-Timestamp + X-Trusteed-Signature (internal HMAC)                   | 10 s    |

| Method | Path                                                            | When                                        | Auth                                                                                                     | Timeout |
|--------|-----------------------------------------------------------------|---------------------------------------------|----------------------------------------------------------------------------------------------------------|---------|
| POST   | /api/v1/internal/<br>magento/manifest/sign                      | Manifest build (remote<br>signing, ADR-050) | X-Trusteed-<br>Connection-Id + X-<br>Trusteed-Timestamp<br>+ X-Trusteed-<br>Signature (internal<br>HMAC) | 5 s     |
| POST   | /api/v1/enforcement/<br>capabilities                            | Once per capability-set<br>version          | HMAC in the body<br>signature field                                                                      | 3 s     |
| POST   | /api/v1/auth/introspect                                         | Setup Wizard token<br>introspection         | bearer token under<br>test                                                                               | 5 s     |
| POST   | /platform/magento/<br>validate-connect-token                    | Setup Wizard connect                        | connect token                                                                                            | 5 s     |
| GET    | /api/v1/trust/overview?<br>merchantId=<id>                      | Health tab render                           | X-Trusteed-<br>Signature (HMAC)                                                                          | 6 s     |
| POST   | /api/v1/coupon-attempts-<br>failed                              | Invalid coupon observer                     | X-Trusteed-<br>Signature (HMAC)                                                                          | 1.5 s   |
| POST   | /api/v1/checkout-<br>failures                                   | Payment-failed observer                     | X-Trusteed-<br>Signature (HMAC)                                                                          | 1.5 s   |
| POST   | /v1/embed/magento/issue-<br>token                               | Admin SPA token<br>issuance                 | X-Embed-Magento-<br>Secret (per-<br>connection<br>embed_secret )                                         | 10 s    |
| POST   | /v1/embed/support/<br>report                                    | Admin "Send<br>diagnostics"                 | Authorization:<br>Bearer<br><integration_token><br>+ X-Embed-Source                                      | 10 s    |
| GET    | /api/v1/checkout-<br>failures/count                             | Agent history signals                       | X-Trusteed-<br>Signature (HMAC)                                                                          | 3 s     |
| GET    | /api/v1/agents/<br><agentIdHash>/cross-<br>merchant-abuse-check | Agent history signals                       | X-Trusteed-<br>Signature (HMAC)                                                                          | 3 s     |
| GET    | /api/v1/merchants/<br><merchantId>/disputes/<br>count           | Agent history signals                       | X-Trusteed-<br>Signature (HMAC)                                                                          | 3 s     |

| Method | Path           | When                                      | Auth | Timeout |
|--------|----------------|-------------------------------------------|------|---------|
| GET    | /api/v1/health | ApiBaseUrlValidator<br>reachability probe | none | 5 s     |

**Timeouts are not uniform** — they differ per caller, as listed above: `EnforcementClient` and `ApiBaseUrlValidator` use 5 s, `Manifest\Builder` 5 s ( `SIGN_TIMEOUT_SECONDS` ), `Webhook\SignaturePublisher` 10 s ( `TIMEOUT_SECONDS` , and it also serves the heartbeat and install-event calls), `Adminhtml\Token\Issue` and `Adminhtml\Support\Submit` 10 s, `Block\Adminhtml\Health\Tab` 6 s ( `SCORE_HTTP_TIMEOUT` ), `AgentHistoryFetcher` 3 s ( `HTTP_TIMEOUT_SECONDS` ), and `CapabilitiesReporter` 3 s. The two fire-and-forget observers are the tightest: 1500 ms total and 800 ms to connect ( `CURLOPT_TIMEOUT_MS` / `CURLOPT_CONNECTTIMEOUT_MS` ), so a slow backend cannot delay a checkout. `ApiBaseUrlValidator` additionally caps connect time at 5 s ( `CONNECT_TIMEOUT_SECONDS` ).

The two `/v1/embed/*` routes use **different secrets, deliberately**: token issuance sends the per-connection `embed_secret` (provisioned by the onboarding exchange and validated against the backend SecretVault by `connection_id` ), while the support report sends the `integration_token` as a bearer. They are not interchangeable.

TLS peer verification is always enabled ( `CURLOPT_SSL_VERIFYPEER=true` , `CURLOPT_SSL_VERIFYHOST=2` ) and HTTP redirects are disabled ( `CURLOPT_FOLLOWLOCATION=false` ). `Manifest\Builder` additionally enforces a closed host allowlist before sending the internal HMAC secret anywhere.

## 16. Security model

### SSRF protection

`Model/Security/ApiBaseUrlValidator.php` validates the admin-configurable `api_base_url` against an allowlist of known Trusted API hostnames. Any attempt to change the API URL to a non-allowlisted host is rejected before any signed payload is sent.

### TLS hardening

All outbound curl calls enforce:

- HTTPS scheme only ( `CURLPROTO_HTTPS` )
- TLS peer and host verification
- No redirect following

## HMAC signing

Calls to `POST /v1/rules/evaluate` are signed with HMAC-SHA256 in Stripe-style format: `t=<timestamp>,s=<hex>`. The signing input is `"<timestamp>.<rawBody>"`. Webhook deliveries use the separate headers and signing input described in [Webhook outbox](#).

## Webhook secret versioning

Every outbox entry stores the webhook secret version that was current when it was queued, and the delivery header `X-Trusteed-Webhook-Secret-Version` carries that version. Rotate secrets by:

1. Updating the secret in Trusteed dashboard
2. Pasting the new secret into Magento config
3. Incrementing `Webhook Secret Version`

## Replay protection

Agent tokens include a `jti` (JWT ID) claim. The module calls `POST /v1/agent-events/nonce-consume` after verifying each token. A 409 response indicates replay, and the module treats the token as `INVALID`.

## 17. Console commands

| Command                               | Class                                           | Description                                                                                                                                                                                                                               |
|---------------------------------------|-------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <code>trusteed:check-webserver</code> | <code>Console/Command/CheckWebserver.php</code> | Fetches <code>/.well-known/mcp.json</code> over the store's unsecure base URL and confirms the response is a real manifest (checks for a top-level <code>schema_version</code> ). On failure prints the Nginx and Apache rewrite snippets |
| <code>trusteed:webhook:status</code>  | <code>Console/Command/WebhookStatus.php</code>  | Prints outbox statistics: pending, delivered, dead counts and oldest pending entry age                                                                                                                                                    |

Both names are registered in `etc/di.xml` under `Magento\Framework\Console\CommandListInterface`.

Usage:

```
bin/magento trusteed:check-webserver
bin/magento trusteed:webhook:status
```

## 18. Data patches

| Patch Class                             | Purpose                                                                                                                                                                                                                                                                       | Idempotent |
|-----------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------|
| <code>AddAgenticVisibleAttribute</code> | Adds <code>is_agentic_visible</code> product EAV attribute (boolean, default 1). Spec-050 FR-A-013 catalog filtering only — <code>Controller/Products/Index.php</code> serves agents just the products flagged <code>1</code> . It is <b>not</b> a rule: no CEL rule reads it | Yes        |
| <code>DisableBridgeOnHyva</code>        | Detects Hyvä or PWA Studio themes and sets <code>trusted_general/features/webmcp_enabled = 0</code> to prevent storefront JS conflicts                                                                                                                                        | Yes        |
| <code>EmitInstallEvent</code>           | Calls <code>POST /api/v1/internal/magento/event</code> to log the installation timestamp and Magento version in the Trusted dashboard                                                                                                                                         | Yes        |
| <code>ReportSignalCapabilities</code>   | Reports which cart signals this installation can project, via <code>POST /api/v1/enforcement/capabilities</code> . Without it a rule whose signal never arrives returns <code>NO_SIGNAL</code> on every checkout — it passes silently while showing as ENFORCE                | Yes        |

## 19. Di.xml wiring

Key dependency injection entries:

```

<!-- EnforcementClient receives the SSRF validator via DI -->
<type name="Trusteed\AgenticCommerce\Service\EnforcementClient">
  <arguments>
    <argument name="urlValidator" xsi:type="object">
      Trusteed\AgenticCommerce\Model\Security\ApiBaseUrlValidator
    </argument>
  </arguments>
</type>

<!-- Console commands -->
<type name="Magento\Framework\Console\CommandListInterface">
  <arguments>
    <argument name="commands" xsi:type="array">
      <item name="trusteed_check_webserver" xsi:type="object">
        Trusteed\AgenticCommerce\Console\Command\CheckWebserver
      </item>
      <item name="trusteed_webhook_status" xsi:type="object">
        Trusteed\AgenticCommerce\Console\Command\WebhookStatus
      </item>
    </argument>
  </arguments>
</type>

```

`Model\Webhook\OutboxRepository` is injected as a **concrete class**. There is no `OutboxRepositoryInterface` and no `<preference>` for it — depend on the class.

See `etc/di.xml` and `etc/frontend/di.xml` for full wiring.

## 20. Logging

All module log entries are prefixed with `[trusteed]` and written to `var/log/system.log` (Magento default logger) at the following levels:

| Level                | Example messages                                                                     |
|----------------------|--------------------------------------------------------------------------------------|
| <code>debug</code>   | Snapshot cache hit, nonce consume ACCEPTED                                           |
| <code>info</code>    | Outbox enqueue success, webhook delivered                                            |
| <code>warning</code> | API timeout, SSRF guard rejection, HMAC verification mismatch, evaluate HTTP non-2xx |
| <code>error</code>   | Fatal configuration missing, outbox drain failure after max retries                  |

To enable debug logging:

```
bin/magento config:set dev/debug/debug_logging 1
```

Or set `MAGE_MODE=developer` in your environment.

## Log grep shortcuts

```
# All Trusted entries
grep '\[trusted\]' var/log/system.log

# Outbox delivery problems only
grep '\[trusted\] webhook\|deliver\|dead\|retry' var/log/system.log

# Enforcement decisions
grep '\[trusted\] evaluate\|BLOCK\|ALLOW\|ESCALATE' var/log/system.log

# Agent token issues
grep '\[trusted\] token\|nonce\|verify\|INVALID\|REPLAY' var/log/system.log
```